

Governance-Driven Agentic Coding

给 Agent 有边界的执行权。用证据支持声明。把复核与生产分开。最终接受权留给人。

证据边界

这是当前公开的 v1.5。它是一套作者维护的小型规范，不是行业标准、合规认证或效果证明。

Qi Sun, CC BY 4.0

它解决什么问题

Agent 可以快速生成实现，但速度不会自动产生授权、正确性或责任归属。GDAC 是一套轻量的委托协议，用来规定谁能做什么、怎样证明做完、谁能否决，以及什么时候必须停。

不是完整 Agent runtime，也不是合规认证。

它不替代 Codex、Claude、CI、代码审查或组织治理。它只连接任务前的可验证结果、执行中的权限边界、任务后的证据与 Owner 决定。

这套结构可以用于不同软件领域，因为核心字段不绑定某个业务行业。但目前实践证据只来自作者主导的两个私有项目，外部读者无法查证，也没有外部采用、独立复现或生产效果证明。

真正承重的只有三个控制

有边界的委托

工作开始前冻结可验收结果、非目标、写权限、预算、停止条件和 Owner 保留决定。Agent 不能自行扩权。

上下文独立复核

重要对象由没有继承 Builder 推理过程的 Reviewer 重新检查。它减少共同盲点，但不等于组织独立、第三方验证或内部审计。

声明完整性

把事实、推断、假设、未知和 Owner 决定分开。代码存在不证明它运行过，测试通过不证明 Owner 已接受，哈希一致不证明语义正确。

一次受治理工作的完整回路

- 1

冻结结果

先写可验证的 outcome 和 acceptance criteria，再开始实现。
- 2

划定权限

写明可写对象、禁止动作、预算、重试上限和停止条件。
- 3

最小实现

复用现有架构，只做满足验收所需的最小变更。
- 4

生成证据

优先使用确定性测试，再按风险加入规则、模型、人类或 Owner 复核。

5

独立挑战

Reviewer 从冻结对象和原始记录出发，寻找遗漏、越权、错误推断和不充分证据。

6

Owner 接受或停止

技术通过只支持决定。它不替 Owner 做发布、风险或不可逆决定。

契约到证据的链条是骨架，但核心不是“链”这个名词。核心是每个状态变化都有明确权限和足够证据，没有证据时不能偷偷前进。

Outcome Contract 是可执行入口

Contract 只在重要或被委托的任务上使用。低风险工作应当缩减内容，而不是仪式性填满字段。

字段	它阻止什么
Outcome 与 acceptance criteria	把“做了很多”误当作“结果已被接受”。
Non-goals	任务在执行中不断扩大。
Authority	Agent 自行改变范围、测试、预算或发布权限。
Budget 与 stop conditions	无限重试、无限递归和沉没成本继续。
Evidence requirements	用最容易获得的证据替代声明真正需要的证据。
Handoff	只交付结果，不交付限制、失败和未决事项。

```
python -m pip install -r requirements-dev.txt
python practice-kit/tools/validate_contract.py \
  practice-kit/examples/outcome-contract.example.yaml
```

机器可读的 JSON Schema、已填写实例和校验器都在仓库内。

权限与复核

方法只需要三类责任。复杂项目可以增加 Orchestrator、Verifier、Red Team 或 Integrator，但新增角色不能改变 Owner 保留权。

责任	可以做	不能做
Owner	冻结目标与权限，接受结果，决定发布、风险和重大方法变更。	不能把责任归因给 Agent 或把缺失证据当作通过。
Producer	在声明的写范围和预算内实现，记录测试、失败与限制。	不能自行扩权、修改验收标准或宣布自己已被接受。
Reviewer	从冻结对象和原始证据重新判断，阻止不充分声明。	不能把上下文隔离包装成第三方独立，也不能代替 Owner 接受。

复核的最低独立性

- Reviewer 不继承 Producer 的隐藏推理或结论摘要。
- 复核输入是冻结对象、验收标准、diff、测试和原始记录。
- Producer 不能单方面选择忽略哪些 material finding。
- 同一模型可以承担不同角色，但这只提供上下文分离，不提供主体独立。

证据先于声明

证据状态

- 事实：**可以直接从记录重现。
- 推断：**由事实支持，但仍包含解释。
- 假设：**尚未经过足够测试的解释或预测。

未知：当前材料不能支持判断。

Owner 决定：接受、风险偏好或授权选择。

三条声明规则

Capability Claim Attestation：agent-ready 不等于 agent-executed。这是可单独执行、可单独判失败的具名规则。

Conclusion Provenance：结论必须能追到对象、版本、证据与决定者。

Derivation Integrity：哈希能证明对象相同，不能单独证明从原始材料到结论的语义推导正确。

确定性测试优先。模型 grader 可以补充能力或对抗性评价，但其配置、输入、输出和失败也必须被记录。缺少声明所需证据时，默认状态是 blocked 或 unknown。

从失败中学习，但不让系统自我授权

项目可以提出方法变化，不能直接激活全局规则。候选规则按 candidate、validated、active、retired 管理，并绑定测试、日志、diff、用户纠正或 preventive check。

- 在看到结果前冻结 baseline、candidate delta 和判定条件。
- 比较候选是否改变了重要决定或更早发现了重要错误。
- 如果只是增加字段、重复已有控制或造成不成比例返工，就缩减或拒绝。
- 项目停止时记录保留物、禁止声明和未解决未知，而不是因为已投入成本继续。

精简后的 Method-Change Re-test 和 Project Closeout 可直接复制。

最小采用方式

不要先建立一个“AI 组织”。先选一项高价值、可回滚、能被测试的真实任务。

1. 复制并缩减 Outcome Contract，冻结后运行校验。
2. 让 Producer 只获得必要写权限，并设定一次或两次重试上限。
3. 让 Reviewer 只读检查冻结对象、diff、测试和原始证据。
4. 由 Owner 明确写下 accepted、rework、blocked 或 stopped。

5. 只在真实采集数据时衡量两个指标：每个 accepted outcome 的 token 成本，以及因为原始证据不足而重新打开的 accepted outcome 比例。

没有真实使用记录时，不报告效率提升、质量提升或风险降低。

当前证据与边界

证据独立性声明

除非具体记录另有说明，当前 GDAC 文档、实例、测试、评审和结论均由作者在 AI 协助下产生、记录和评价。没有独立第三方复现本方法，也没有证据证明它改善了真实交付、安全、成本或治理结果。

- v1.5 是当前公开版本，但尚未经过外部独立复现。
- 结构可以跨领域复用，不代表已经跨领域验证。
- AI Act 或其他监管 overlay 只能做证据映射和风险提示，不构成合规认证。
- 现有测试证明 schema 和校验器在给定样例上工作，不证明组织采用价值。

完整对照见 Related Work and Boundaries。它说明 GDAC 与 NIST AI RMF、IIA Three Lines、SR 26-2、EU AI Act、ADR、in-toto、SLSA、preregistration、Inspect 和 AGENTS.md 的关系与差异。